

SIMATS ENGINEERING
ASSESSMENT TOOL II – INDUSTRY PROBLEM TASK

Course:	Code:	CO: CO5
Duration:	Total Marks: 100	Reg No / Name:

COURSE OUTCOME COVERED

CO5: *Analyze vulnerabilities in Windows and Linux systems and evaluate security weaknesses in messaging, web, and mobile applications using appropriate exploitation techniques and hacking tools. (BT5)*

Instructions: *Answer all questions. Each question carries 20 marks.*

1. A mid-sized financial organization operates a Windows domain network consisting of 150 interconnected systems. During a security incident investigation, it is observed that attackers have exploited NULL sessions, open RPC services, and misconfigured shared folders to gain unauthorized access. Initial analysis indicates that 45% of systems allow anonymous enumeration, and among those, 60% are susceptible to SMB-based lateral movement attacks. Furthermore, each compromised system can attempt to access 3 additional systems, with a success probability of 0.3 per attempt.

Question:

Analyze the extent of the attack by calculating the number of systems compromised during the initial stage of exploitation. Further, estimate the spread of the attack in the second stage due to lateral movement. Based on your analysis, evaluate whether the network is at risk of a large-scale compromise (greater than 70% of total systems), and justify which vulnerability (NULL sessions, RPC exposure, or weak shares) should be prioritized for immediate mitigation.

2. An enterprise network consists of 120 systems, out of which 70 systems expose RPC services to the internal network. A vulnerability scan reveals that 40% of these systems are susceptible to known exploits, and the probability of successful exploitation for each vulnerable system is 0.5. However, each exploitation attempt carries a detection probability of 0.25 due to intrusion detection systems deployed within the network.

Question:

Determine the expected number of systems that can be successfully compromised by an attacker. Additionally, compute the expected number of detection alerts generated during the exploitation process. Based on your results, critically evaluate whether an attacker aiming to remain stealthy would proceed with exploitation or adopt alternative attack strategies, providing justification for your reasoning.

3. A cloud-hosted Linux server is running multiple services exposed to the internet. Security analysis identifies four critical services, with independent probabilities of vulnerability being 0.3, 0.2, 0.25, and 0.15, respectively. It is also observed that the system has weak file permissions, which can be exploited with a probability of 0.5 once initial access is gained.

Question:

Evaluate the probability that at least one service is vulnerable and can be exploited by an attacker. Further, compute the overall probability of a full system compromise, considering both service exploitation and privilege escalation through weak permissions. Based on your findings, analyze whether strengthening file permissions alone would significantly reduce the overall risk, and justify your conclusion.

CO5 – ASSESSMENT TOOL II

INDUSTRY PROBLEM TASK – DETAILED SOLUTIONS

Student Name: K Nitheesh Kumar

Register Number: 192325090

Course Outcome Covered: CO5 – Analyze vulnerabilities in Windows and Linux systems and evaluate security weaknesses in messaging, web, and mobile applications using appropriate exploitation techniques and hacking tools (BT5). The assessment contains five questions, each carrying 20 marks, for a total of 100 marks.

The five industry scenarios cover a financial Windows domain network, an enterprise RPC environment, a cloud-hosted Linux server, NFS across internal subnets, and an e-commerce database exposed to SQL injection.

Method used: Each solution first translates the stated percentages/probabilities into expected values, then interprets the result from a security-risk perspective. Calculations are shown step by step so that the numerical reasoning can be verified.

QUESTION 1 – WINDOWS DOMAIN NETWORK: NULL SESSIONS, RPC AND WEAK SHARES

1.1 Problem Understanding

The organization has 150 interconnected systems. Attackers have exploited NULL sessions, open RPC services and misconfigured shared folders. The problem states that 45% of systems allow anonymous enumeration, 60% of those are susceptible to SMB-based lateral movement, and each compromised system can attempt access to three additional systems with a 0.3 success probability per attempt. The task is to calculate the initial compromise, estimate second-stage spread, decide whether more than 70% of the network could be compromised, and prioritize the vulnerability for immediate mitigation. 穀filecite學turn6file0學L11-L24倅

1.2 Stage One – Anonymous Enumeration Exposure

Total systems = 150

Systems allowing anonymous enumeration = $150 \times 45\% = 150 \times 0.45 = 67.5 \approx 68$ systems

Because a physical system count must be an integer, the mathematical expectation is 67.5 systems; operationally this corresponds to approximately 68 systems. However, the question adds an important condition: only 60% of these systems are susceptible to SMB-based lateral movement. Therefore, the population that can progress through the stated SMB compromise path is calculated next.

Potentially susceptible systems = $67.5 \times 60\% = 67.5 \times 0.60 = 40.5 \approx 41$ systems

For the remainder of this answer, 40.5 is retained as the expected value so that the probability calculations remain mathematically consistent. Thus, the expected initial-stage compromise population for the specified SMB lateral-movement path is 40.5 systems.

1.3 Stage Two – Lateral Movement

Each compromised system attempts to access three additional systems. Each attempt has an independent success probability of 0.3. Therefore, the expected number of successful lateral-movement compromises generated by each compromised system is:

Expected new compromises per system = $3 \times 0.3 = 0.9$

Second-stage expected compromises = $40.5 \times 0.9 = 36.45$ systems

This means the second stage is expected to compromise approximately 36 additional systems. The value is an expectation, not a guarantee; actual results could be lower or higher depending on which systems are targeted, overlap between attempts, segmentation and other controls.

1.4 Total Expected Compromise

Total expected = initial stage + second stage

= $40.5 + 36.45 = 76.95$ systems

Percentage of 150 = $(76.95 / 150) \times 100 = 51.3\%$

The expected compromise level is therefore approximately 51.3% of the network under the stated two-stage model.

1.5 Is the Network at Risk of >70% Compromise?

70% of 150 = 105 systems

Expected total = 76.95 systems < 105 systems

Under the exact two-stage assumptions given in the question, the network is not expected to cross the 70% large-scale-compromise threshold. However, the risk is still serious because more than half of the network could be affected in expectation, and the model describes only two stages. Additional stages, credential reuse, trust relationships and other vulnerabilities could increase the real-world spread.

1.6 Vulnerability Prioritization

Vulnerability	Role in Attack	Priority	Reason
NULL sessions	Enables anonymous enumeration	Critical / Immediate	Broad 45% exposure makes it an important initial access and information-disclosure enabler.
Open RPC	Provides remote service exposure	High–Critical	Can expose powerful Windows functionality and facilitate exploitation or lateral movement.
Weak shared folders	Enables unauthorized/weakly controlled access	High	Directly contributes to SMB-based lateral movement and data exposure.

NULL sessions should receive immediate priority because they are the earliest broad enabler in the stated chain: 45% of systems permit anonymous enumeration. Removing anonymous enumeration reduces attacker visibility and weakens the initial discovery stage. At the same time, RPC exposure and weak shares must be remediated because they remain direct contributors to lateral movement.

1.7 Mitigation

- Disable unnecessary anonymous/NULL-session access and anonymous enumeration.
- Restrict SMB and RPC communication to systems that require it.
- Harden shared-folder permissions using least privilege and explicit access groups.
- Segment the Windows domain into security zones to reduce lateral movement.
- Monitor SMB/RPC traffic and unusual authentication patterns.
- Remove stale accounts and enforce strong authentication.
- Apply security updates to Windows servers and domain infrastructure.
- Use endpoint detection and centralized event logging.

QUESTION 1 – DETAILED NETWORK-SPREAD ANALYSIS

1.8 Probability Interpretation

The second-stage calculation uses an expected-value model. A compromised system has three opportunities and each opportunity succeeds with probability 0.3. The expected number of successful outcomes is 0.9, even though a single system cannot literally compromise 0.9 of a machine. Across many compromised systems, however, expected values are meaningful.

1.9 Probability of at Least One Successful Lateral Attempt

$$P(\text{no success in 3 attempts}) = (1 - 0.3)^3 = 0.7^3 = 0.343$$

$$P(\text{at least one success}) = 1 - 0.343 = 0.657 = 65.7\%$$

Thus, a compromised system has a 65.7% probability of achieving at least one successful lateral-movement attempt, assuming independent attempts and the same 0.3 success probability. This reinforces why lateral-movement controls are important even when the expected number of new systems per compromised host is less than one.

1.10 Security Interpretation

The most dangerous characteristic is not only the number of initially exposed systems but the presence of connectivity between compromised and uncompromised systems. A network with excessive trust, broad SMB access and weak shared-folder permissions can turn a local compromise into a domain-wide incident. Segmentation and least privilege reduce the branching factor of the attack.

1.11 Final Answer for Q1

Expected initial-stage compromise through the specified SMB path is 40.5 systems (approximately 41). The expected second-stage lateral movement is 36.45 systems, producing an expected total of 76.95 systems or 51.3% of the 150-system network. This is below the 70% threshold of 105 systems, but still represents a severe large-scale incident. NULL sessions should be prioritized immediately because they enable anonymous enumeration across 45% of systems; open RPC services and weak shares should be remediated in parallel because they support exploitation and lateral movement.

QUESTION 2 – RPC EXPOSURE, EXPLOIT SUCCESS AND DETECTION

2.1 Problem Understanding

The enterprise has 120 systems, 70 of which expose RPC services internally. Forty percent of those 70 systems are susceptible to known exploits. Each vulnerable system has a 0.5 probability of successful exploitation, while each exploitation attempt has a 0.25 probability of generating a detection alert. The task asks for expected compromises, expected alerts and a stealthiness decision. 穀filecite學turn6file0學L25-L35傢

2.2 Number of Vulnerable RPC Systems

RPC-exposed systems = 70

Susceptible systems = $70 \times 40\% = 70 \times 0.40 = 28$ systems

Therefore, 28 systems are expected to be vulnerable to the known exploits.

2.3 Expected Successful Compromises

Expected successful compromises = $28 \times 0.5 = 14$ systems

The expected number of successfully compromised systems is 14. This is an expected value based on the stated independent 0.5 success probability.

2.4 Expected Detection Alerts

Expected alerts = $28 \times 0.25 = 7$ alerts

The expected number of detection alerts generated during the exploitation process is 7. This does not mean exactly seven alerts will always occur; it is the mathematical expectation.

2.5 Probability of Remaining Undetected Across All Attempts

$P(\text{no alert per attempt}) = 1 - 0.25 = 0.75$

$P(\text{no alerts across 28 attempts}) = 0.75^{28} \approx 0.000318$

$P(\text{at least one alert}) = 1 - 0.75^{28} \approx 0.999682 = 99.97\%$

Under the simplified independent-attempt model, there is approximately a 99.97% probability that at least one alert will be generated if all 28 vulnerable systems are attacked. This is a much stronger stealth warning than the expected value of seven alerts alone.

2.6 Would a Stealthy Attacker Proceed?

An attacker whose primary objective is stealth would have strong reason not to launch exploitation against all 28 vulnerable systems in a single obvious campaign. The expected compromise benefit is 14 systems, but the expected alert count is seven and the probability of at least one alert is approximately 99.97%. A stealth-oriented actor would therefore likely reduce noisy activity, seek a smaller initial foothold, or pursue alternative paths that generate less detectable traffic.

2.7 Defensive Recommendation

- Prioritize patching the 28 vulnerable RPC-exposed systems.
- Restrict RPC exposure to required internal hosts and management networks.
- Tune IDS/IPS rules to identify suspicious RPC exploitation patterns.

- Correlate network alerts with endpoint process and authentication events.
- Use segmentation to prevent one compromised system from reaching all RPC-exposed hosts.
- Remove unnecessary RPC services where possible.
- Conduct controlled validation after patching.

QUESTION 3 – CLOUD LINUX SERVICES AND WEAK FILE PERMISSIONS

3.1 Problem Understanding

The cloud-hosted Linux server has four Internet-exposed critical services. Their independent probabilities of vulnerability are 0.3, 0.2, 0.25 and 0.15. Once initial access is gained, weak file permissions can be exploited for privilege escalation with probability 0.5. The question asks for the probability of at least one vulnerable service, the overall probability of full compromise and whether fixing file permissions alone significantly reduces risk.

3.2 Probability of No Vulnerable Service

$$\begin{aligned} P(\text{no vulnerability}) &= (1-0.3)(1-0.2)(1-0.25)(1-0.15) \\ &= 0.7 \times 0.8 \times 0.75 \times 0.85 \\ &= 0.357 \end{aligned}$$

3.3 Probability of At Least One Vulnerable Service

$$\begin{aligned} P(\text{at least one vulnerable service}) &= 1 - 0.357 = 0.643 \\ &= 64.3\% \end{aligned}$$

There is therefore a 64.3% probability that at least one of the four services is vulnerable under the independent-probability model.

3.4 Full System Compromise

The question states that weak file permissions can be exploited with probability 0.5 once initial access is gained. Therefore, full compromise requires two events: at least one service is vulnerable/exploitable and the privilege-escalation opportunity succeeds.

$$\begin{aligned} P(\text{full compromise}) &= P(\text{initial service compromise}) \times P(\text{privilege escalation} \mid \text{initial access}) \\ &= 0.643 \times 0.5 = 0.3215 \\ &= 32.15\% \end{aligned}$$

The overall probability of full system compromise is therefore 32.15%, assuming the stated independence/conditional relationship.

3.5 Would File-Permission Hardening Alone Be Enough?

No. Strengthening file permissions would remove or reduce the stated privilege-escalation path, potentially reducing the full-compromise probability attributable to that path to near zero. However, the probability of an initial service vulnerability remains 64.3%. Attackers could still obtain limited access, steal application data, abuse credentials, exploit another local weakness or search for additional escalation paths.

Control	Effect on Risk
Patch exposed services	Reduces the 64.3% initial vulnerability probability.
Harden file permissions	Reduces the 0.5 conditional escalation probability.
Network restrictions	Reduces Internet exposure of unnecessary services.
Least privilege	Limits impact after initial compromise.
Monitoring	Improves detection and response.

3.6 Final Answer for Q3

At least one service is vulnerable with probability 64.3%. The probability of full compromise, including the stated 0.5 privilege-escalation probability, is 32.15%. File-permission hardening is valuable but is not sufficient by itself because it does not remove the large initial attack surface created by four Internet-exposed critical services. The correct strategy is layered: patch services, minimize exposure, harden permissions and monitor the host.

QUESTION 4 – NFS ACCESS ACROSS THREE SUBNETS

4.1 Problem Understanding

The organization uses NFS across three internal subnets. Unauthorized-access probabilities are 0.4, 0.3 and 0.2. Once access to the NFS share is obtained, the probability of privilege escalation to root is 0.7. The question asks for the probability that at least one subnet gains unauthorized access, the complete-compromise probability and the effectiveness of restricting NFS to one subnet. 穀filecite學turn6file0學L47-L55像

4.2 Probability of No Unauthorized Access

$$P(\text{no access from subnet 1}) = 1 - 0.4 = 0.6$$

$$P(\text{no access from subnet 2}) = 1 - 0.3 = 0.7$$

$$P(\text{no access from subnet 3}) = 1 - 0.2 = 0.8$$

$$P(\text{no unauthorized access from any subnet}) = 0.6 \times 0.7 \times 0.8 = 0.336$$

4.3 At Least One Unauthorized Access

$$P(\text{at least one unauthorized access}) = 1 - 0.336 = 0.664$$

$$= 66.4\%$$

Therefore, the probability that at least one subnet successfully obtains unauthorized NFS access is 66.4%.

4.4 Complete System Compromise

$$P(\text{complete compromise}) = 0.664 \times 0.7 = 0.4648$$

$$= 46.48\%$$

The expected overall probability of complete compromise under the stated model is 46.48%.

4.5 Restricting NFS to a Single Subnet

Restricting NFS access to one subnet reduces the number of independent opportunities for unauthorized access. If the organization can choose which single subnet is permitted, the lowest unauthorized-access probability is subnet 3 at 0.2. Restricting access there would produce:

$$P(\text{unauthorized NFS access}) = 0.2 = 20\%$$

$$P(\text{complete compromise}) = 0.2 \times 0.7 = 0.14 = 14\%$$

Compared with the original 46.48% complete-compromise probability, this represents a reduction of 32.48 percentage points, or approximately a 69.9% relative reduction.

4.6 Caveat

The recommendation assumes the selected subnet can legitimately support all required NFS users and that the other subnets do not need direct NFS access. If business requirements require multiple subnets, access should instead be restricted to specifically authorized hosts or security groups, with strong export permissions and network controls.

4.7 Final Answer for Q4

At least one subnet gains unauthorized access with probability 66.4%, and complete compromise is 46.48%. Restricting NFS to one carefully selected subnet is an effective mitigation because it removes two independent exposure paths. If the 20% subnet is the permitted one, the modeled complete-compromise probability falls to 14%. NFS access should therefore be limited to the minimum required network scope.

QUESTION 5 – SQL INJECTION AGAINST 50,000 USER RECORDS

5.1 Problem Understanding

The e-commerce database contains 50,000 user records, with 30% classified as sensitive. A successful SQL injection attack extracts 500 records per second, while the application firewall blocks the attack after 40 seconds. The task is to calculate extracted records, percentage of total data compromised, sensitive records exposed and breach severity. 穀filecite學turn6file0學L56-L64倅

5.2 Total Records Extracted

Extraction rate = 500 records/second

Detection/block time = 40 seconds

Records extracted = $500 \times 40 = 20,000$ records

The attack can therefore extract 20,000 records before the firewall blocks it, assuming the extraction rate remains constant for the entire 40-second interval.

5.3 Percentage of Total Data Compromised

Percentage compromised = $(20,000 / 50,000) \times 100$
= 40%

The attacker can therefore obtain 40% of the entire user-record database before being blocked.

5.4 Sensitive Records Exposed

Sensitive records = $50,000 \times 30\% = 15,000$

Sensitive records exposed = $20,000 \times 30\% = 6,000$

Assuming the extracted records have the same 30% sensitive proportion as the overall database, approximately 6,000 sensitive records are exposed.

5.5 Alternative Worst-Case Interpretation

The 6,000 figure is an expected/proportional estimate. If an attacker deliberately targets the most sensitive records first, the number of sensitive records exposed could be higher—up to 15,000 in the extreme case where all extracted records are sensitive until the sensitive population is exhausted. The question's percentage-based structure supports the proportional estimate of 6,000.

5.6 Breach Severity

Measure	Result	Security Meaning
Total records	50,000	Large user-data population.
Extracted	20,000	40% of database compromised.
Sensitive population	15,000	Substantial high-value data.
Sensitive exposed	≈6,000	Significant privacy/security impact.
Block time	40 seconds	Detection stops further extraction but not initial loss.

5.7 Is the Firewall Sufficient?

No. The firewall is useful because it detects and blocks the SQL injection after 40 seconds, but it allows a very large amount of data to be extracted first. A 40-second window at 500 records per second permits 20,000 records to leave the database. This demonstrates that perimeter detection is not a substitute for preventing SQL injection.

5.8 Mitigation

- Use parameterized queries/prepared statements.
- Validate input on the server and avoid constructing SQL from untrusted strings.
- Apply least privilege to database accounts.
- Separate application and database network zones.
- Monitor abnormal query and extraction behavior.
- Use database activity monitoring where appropriate.
- Deploy WAF protections as defense in depth, not as the primary control.
- Encrypt sensitive data at rest and in transit.
- Maintain tested backups and incident-response procedures.
- Rotate credentials and assess downstream exposure after an injection incident.

QUESTION 5 – DETAILED BREACH ANALYSIS

5.9 Data-Extraction Timeline

Time	Cumulative Records Extracted	% of 50,000
0 s	0	0%
10 s	5,000	10%
20 s	10,000	20%
30 s	15,000	30%
40 s	20,000	40%

5.10 Why Prevention Is More Important Than Blocking

The firewall's 40-second detection delay illustrates the difference between detection and prevention. Once an SQL injection is successfully executing a data-extraction query, every second before containment creates additional data loss. Parameterized SQL prevents attacker input from becoming executable query structure in the first place. Least-privilege database permissions then limit what the application account can read even if another application weakness is present.

5.11 Final Answer for Q5

At 500 records per second for 40 seconds, 20,000 records can be extracted. That equals 40% of the 50,000-record database. With 30% of records classified as sensitive, the proportional estimate is 6,000 sensitive records exposed. This is a severe breach because a large fraction of the database is compromised before detection. The firewall is valuable as defense in depth, but it is not sufficient; secure SQL coding, database least privilege, monitoring and rapid containment are essential.

OVERALL CO5 INDUSTRY RISK ANALYSIS

6.1 Consolidated Results

Question	Key Calculation	Final Result	Risk Interpretation
1	$150 \times 0.45 \times 0.60$; then $\times 3 \times 0.30$	76.95 expected systems total; 51.3%	Severe lateral-movement risk, but below 70% threshold.
2	$70 \times 0.40 \times 0.50$; alerts $70 \times 0.40 \times 0.25$	14 compromises; 7 alerts	Stealthy mass exploitation is highly detectable.
3	$1 - (.7 \times .8 \times .75 \times .85)$; $\times .5$	64.3% service vulnerability; 32.15% full compromise	Service exposure remains major risk even after permission hardening.
4	$1 - (.6 \times .7 \times .8)$; $\times .7$	66.4% access; 46.48% complete compromise	Single-subnet restriction can greatly reduce risk.
5	500×40 ; /50,000	20,000 records; 40%; $\approx 6,000$ sensitive	Severe breach despite firewall detection.

6.2 Common Security Principles

- Reduce attack surface by disabling unnecessary services and access paths.
- Apply least privilege to users, services, file shares and database accounts.
- Use network segmentation to limit lateral movement.
- Patch known vulnerabilities promptly using risk-based change management.
- Use secure application development practices such as parameterized SQL and strong session/input controls.
- Treat detection controls as defense in depth rather than substitutes for prevention.
- Automate security-policy enforcement and compliance checking.
- Continuously monitor authentication, network and application events.

6.3 Engineering Decision Framework

The calculations show why security decisions should combine probability with impact. A moderate probability can still produce unacceptable risk when the asset population is large or the impact per compromise is severe. Conversely, a control that reduces exposure from multiple independent paths can produce a large overall risk reduction. Engineering teams should therefore prioritize controls that break attack chains at multiple points.

6.4 Final Conclusion

The five problems demonstrate quantitative security analysis across Windows, Linux, network file sharing and web/database environments. In Question 1, the modeled two-stage attack reaches an expected 51.3% of the network, making NULL-session removal, RPC restriction and share hardening urgent. In Question 2, 14 expected compromises are accompanied by an approximately 99.97% chance of at least one alert across 28 exploitation attempts, making broad exploitation unattractive to a stealth-focused attacker. In Question 3, the 64.3% chance of at least one vulnerable service shows why file-permission hardening alone cannot address the full attack surface. In Question 4, restricting NFS to one appropriately selected subnet can reduce modeled complete compromise from 46.48% to 14%. In Question 5, a 40-second detection delay permits 20,000 records to be extracted, proving that prevention through secure SQL design is essential.

Overall, the strongest strategy is defense in depth: reduce exposure, patch vulnerable components, enforce least privilege, segment networks, protect sensitive data, monitor continuously and maintain tested incident-response procedures. These measures align with the CO5 requirement to analyze vulnerabilities and evaluate security weaknesses using appropriate concepts and tools. 穀filecite學turn6file0學L6-L10傢

STUDENT DECLARATION

I K Nitheesh Kumar (192325090) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: K Nitheesh Kumar

Register Number: 192325090

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning	Mark
Understanding of Industry Problem	20%	Comprehensive understanding of real-world problem and constraints	Good understanding with minor gaps in requirements	Basic understanding; some requirements unclear	Poor understanding; misinterprets problem context	
Application of Engineering Concepts	25%	Applies advanced and relevant concepts effectively to solve the problem	Applies appropriate concepts with minor errors	Limited application of concepts	Incorrect or no application of concepts	
Solution Design	25%	Innovative, practical, and feasible solution aligned with industry standards	Logical and feasible solution with minor gaps	Basic solution with limited feasibility	Unclear or impractical solution	
Use of Tools	15%	Effective use of modern tools, technologies, and real data	Appropriate use of tools with correct implementation	Limited or inconsistent use of tools	Minimal or incorrect use of tools	
Analysis	10%	Thorough analysis with validated results and performance evaluation	Good analysis with reasonable validation	Basic analysis with limited validation	Poor or no analysis	
Professionalism	5%	Highly professional, well-documented, and clearly presented work	Good documentation and presentation	Basic documentation with some gaps	Poor documentation and presentation	